



Mansoura University
Faculty of Computers and Information



Operating Systems

Security

Dr. Mohamed Handosa

Assistant Professor of Computer Science

handosa@mans.edu.eg

The Security Problem

- A **secure system** ensures resources are used and accessed only as intended, under all circumstances.
 - Perfect security is unachievable.
 - Systems face accidental and malicious threats.
 - Malicious threats are much harder to prevent.
- A **threat** is any potential violation of security.
- An **attack** is the actual attempt to breach the system.
- **Intruders (crackers)** exploit software vulnerabilities to gain access.

Security Violation Categories

Security violations can be grouped into the following types:

- **Breach of Integrity:** unauthorized data modification.
- **Theft of Service:** unauthorized use of system resources.
- **Breach of Confidentiality:** unauthorized access to sensitive data.
- **Breach of Availability:** disruption of access or destruction of data.
- **Denial of Service (DoS):** overwhelming the system to prevent use.

Security Violation Methods

Several methods are commonly used in attacks:

- **Masquerading**: pretending to be another user to gain access.
- **Replay Attacks**: reusing captured messages to fool the system.
- **Man-in-the-Middle (MITM)**: intercepting messages to read/alter.
- **Session Hijacking**: taking over a session to bypass authentication.

Security Measure Levels

- Security should be layered across multiple domains:
 - **Physical Security:** protect data centers, servers, and devices.
 - **Operating System Security:** enforce access controls and fix bugs.
 - **Network Security:** protect against sniffing, interception, and DoS attacks.
 - **Human Security:** prevent social engineering, phishing, and careless behaviors.
- Security is only as strong as the weakest link.
- However, excessive security may reduce usability.

Program Threats

Software may contain threats in the form of hidden malicious code:

- **Logic Bomb**

- Code that activates under certain conditions (e.g., file deletion).

- **Trojan Horse**

- A useful-looking program with harmful behavior (e.g., spyware).

- **Trapdoor (Backdoor)**

- Undocumented access built into the software (e.g., bypass login).

- **Buffer Overflow**

- Exploiting unchecked input to overwrite memory and execute code.

Buffer Overflow

- Occurs when a program writes beyond the allocated memory.
- Common in languages like C that lack built-in bounds checking.
- Attackers exploit buffer overflow to **overwrite the return address**.
 - This allows them to redirect execution to their injected code.
- **Prevention:** stack canaries, bounds checking, and using safe libraries.

System Threats

- **Spoofing**
 - Falsely assuming a trusted identity (e.g., IP or email spoofing).
- **Session Hijacking**
 - Taking over an active user session by stealing tokens or cookies.
- **Privilege Escalation**
 - Gaining higher access than intended (e.g., from user to root/admin).

Network Threats

- **Packet Sniffing**
 - Intercepting unencrypted network traffic.
- **Man-in-the-Middle**
 - Intercepting communication between two parties.
- **Denial of Service (DoS)**
 - Flooding the system with fake traffic to exhaust resources.
- **Replay Attacks**
 - Repeating captured communications (e.g., login requests).

User Authentication

- Authentication verifies a user's identity before granting access.
- Types of authentication:
 - **Something you know:** Passwords, PINs
 - **Something you have:** Smart cards, OTP tokens
 - **Something you are:** Biometrics (fingerprint, retina)
- **Multi-factor authentication (MFA)**
 - Combines multiple authentication types to strengthen security.

Password-Based Authentication

- The most common but vulnerable.
- **Best practices**
 - Avoid reuse across sites.
 - Use strong, long, and complex passwords.
 - Store password hashes, not plaintext (e.g., using bcrypt, PBKDF2).
- **Attacks**
 - **Brute-force**: Trying all combinations.
 - **Dictionary attack**: Trying common passwords.
 - **Social engineering**: Tricking users into revealing passwords.

Password Vulnerabilities

- **Keylogging:** Software or hardware capturing keystrokes.
- **Shoulder surfing:** Watching someone enter their password.
- **Phishing:** Pretending to be a trusted source to collect credentials.

Encryption

- Transforms **plaintext** into **ciphertext** to protect confidentiality.
- **Symmetric Encryption**
 - The **same key** is used for both encryption and decryption.
 - Fast and efficient, but secure key exchange is a challenge.
 - **Examples:** AES, DES
- **Asymmetric Encryption**
 - Uses two different keys, a **public key** and a **private key**.
 - Enables secure communication without pre-shared secrets.
 - **Examples:** RSA, Elliptic Curve Cryptography (ECC)

Hash Functions

- One-way functions.
- Produce a fixed-size digest from input data.
- Used for verifying data integrity and storing password hashes.
- **Examples:** SHA-256, SHA-3

Digital Certificates and PKI

- **Digital Certificate**

- Binds a public key to an entity (user, organization).
- Issued and signed by a trusted authority (Certificate Authority, or CA).
- Includes: identity info, public key, CA signature, expiration

- **Public Key Infrastructure (PKI)**

- Manages issuance, distribution, and revocation of certificates.
- Enables secure authentication and encrypted communication over Internet.
- Basis of **HTTPS**, **VPN**, and **email security**.

System Security Defenses

- **Trusted Computing Base (TCB)**

- The set of components responsible for enforcing security.
- Includes the OS kernel, secure boot mechanisms, and system libraries.

- **Security Auditing**

- Keeps logs of access attempts, successful logins, file modifications, etc.
- Helps detect intrusions and support forensic investigations.

- **Intrusion Detection Systems (IDS)**

- **Signature-based IDS:** Detects known attack patterns.
- **Anomaly-based IDS:** Detects unusual behavior or deviations.

Firewalls

- Control incoming and outgoing network traffic under security rules.
- Firewall Types:
 - **Packet-Filtering Firewall:** Inspects headers (IP, port, protocol).
 - **Stateful Firewall:** Tracks connection state (TCP session tracking).
 - **Application Firewall (Proxy):** Understands application-level protocols (HTTP).

Virtual Private Network (VPN)

- VPNs create encrypted tunnels over public networks.
 - Protect against sniffing and MITM attacks.
 - Allow secure remote access to private networks.
 - **Common protocols:** IPsec, OpenVPN, WireGuard

Security Classifications

- Security models often apply clearance levels to users and sensitivity labels to data to enforce strict access control.
- Bell-LaPadula Model (Confidentiality-Focused)
 - Used in military-grade security systems.
 - Based on two key rules:
 - **No Read Up:** A subject can't read data at a higher classification.
 - **No Write Down:** A subject can't write data to a lower classification level.
 - Ensures sensitive data does not leak to lower-clearance users.

Access Control Models

- **Discretionary Access Control (DAC)**
 - The owner of the object decides who can access it.
 - **Example:** File permissions in Windows or Linux.
- **Mandatory Access Control (MAC)**
 - Access decisions are enforced by the system.
 - Users can't change access rules (e.g., used in classified environments).
- **Role-Based Access Control (RBAC)**
 - Access is assigned to roles, and users are assigned to roles.
 - **Example:** "Doctor" role can access patient records; "Receptionist" cannot.

Thank You